

# OSINT Pentester para pruebas de penetración



**Explicar el rol del OSINT Pentester dentro de la fase de inteligencia y reconocimiento para pruebas de penetración.**

**ReadME:** El siguiente texto abordará la relación existente entre el reconocimiento, el OSINT y la inteligencia dentro de la fase de recolección de información, destacando cómo este proceso resulta fundamental para lograr que una prueba de penetración sea eficiente y altamente productiva. Asimismo, se pondrá en valor el rol del **“OSINT Pentester”**, resaltando sus habilidades, competencias y la manera en que este perfil

estratégico puede aportar conocimiento y fortalecer el trabajo de un equipo de **Red Team** en el contexto de las pruebas de penetración.

Comenzaremos la publicación describiendo brevemente las fases estándar de una prueba de penetración, para luego conectar directamente con la relevancia del **rol del OSINT Pentester** en la fase de *Intelligence Gathering*.

## Fases Estándar de una Prueba de Penetración

- Interacciones previas a la interacción
- Recopilación de inteligencia
- Modelado de amenazas
- Análisis de vulnerabilidades
- Explotación
- Post explotación
- Informes

Una prueba de penetración (o *Pentest*) es un proceso estructurado que busca evaluar la seguridad de un sistema, red o aplicación simulando los métodos que un atacante real podría utilizar. Para garantizar resultados precisos y consistentes, las pruebas se desarrollan siguiendo una serie de **fases estandarizadas** que permiten planificar, ejecutar y documentar cada paso del proceso.

### 1. Interacciones previas a la interacción

En esta primera fase se definen los objetivos, el alcance, las reglas de compromiso y las limitaciones del proyecto. Es un paso esencial para establecer una comunicación clara entre el cliente y el equipo de pentesting, asegurando que las pruebas se realicen dentro de los límites éticos y legales acordados.

### 2. Recopilación de inteligencia

También conocida como fase de reconocimiento, consiste en recopilar toda la información posible sobre el objetivo antes de iniciar los ataques activos. Aquí entra en juego el **OSINT (Open Source Intelligence)**, una disciplina clave que permite obtener

datos públicos y accesibles que, al ser correctamente procesados y analizados, se convierten en inteligencia útil para orientar las siguientes etapas del pentest.

### 3. Modelado de amenazas

En esta etapa se analizan los datos obtenidos durante el reconocimiento para identificar vectores de ataque potenciales, activos críticos y posibles vulnerabilidades. Se construyen escenarios de amenaza realistas que guían el enfoque técnico de la prueba.

### 4. Análisis de vulnerabilidades

Implica el análisis y correlación de la información recopilada para detectar vulnerabilidades existentes. Se utilizan herramientas automatizadas y análisis manuales para determinar debilidades en configuraciones, software o políticas de seguridad.

### 5. Explotación

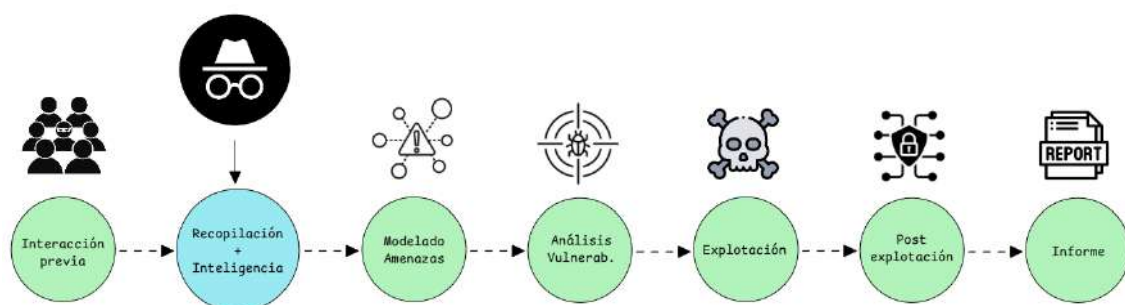
En esta fase se ejecutan los ataques controlados para validar la existencia y el impacto de las vulnerabilidades identificadas. El objetivo no es causar daño, sino demostrar el riesgo real que representan.

### 6. Post explotación

Una vez comprometido el sistema, se evalúa el nivel de acceso alcanzado, el impacto potencial y las rutas de escalamiento de privilegios. También se analiza la persistencia y la posibilidad de movimiento lateral dentro del entorno.

### 7. Informes

Finalmente, se elabora un informe técnico y ejecutivo que documenta los hallazgos, vulnerabilidades explotadas, impacto, evidencia y recomendaciones para mitigar los riesgos. Es la fase que traduce los resultados técnicos en valor estratégico para la organización.



## El Rol del OSINT Pentester en la Fase de Inteligencia

Dentro del ciclo de una prueba de penetración, la fase de **Recopilación de inteligencia** o **reconocimiento** es el punto de partida operativo. Todo lo que ocurra en las etapas posteriores —modelado de amenazas, explotación o análisis de vulnerabilidades— depende en gran medida de la calidad y profundidad de la información obtenida en este primer momento.

Aquí es donde emerge la figura del **OSINT Pentester**, un perfil especializado que combina técnicas de **hacking ético** con metodologías de **inteligencia de fuentes abiertas (OSINT)**. Su misión es **recolectar, procesar y transformar datos públicos** en inteligencia accionable, aportando una comprensión más precisa del entorno objetivo antes de realizar cualquier interacción directa con él.

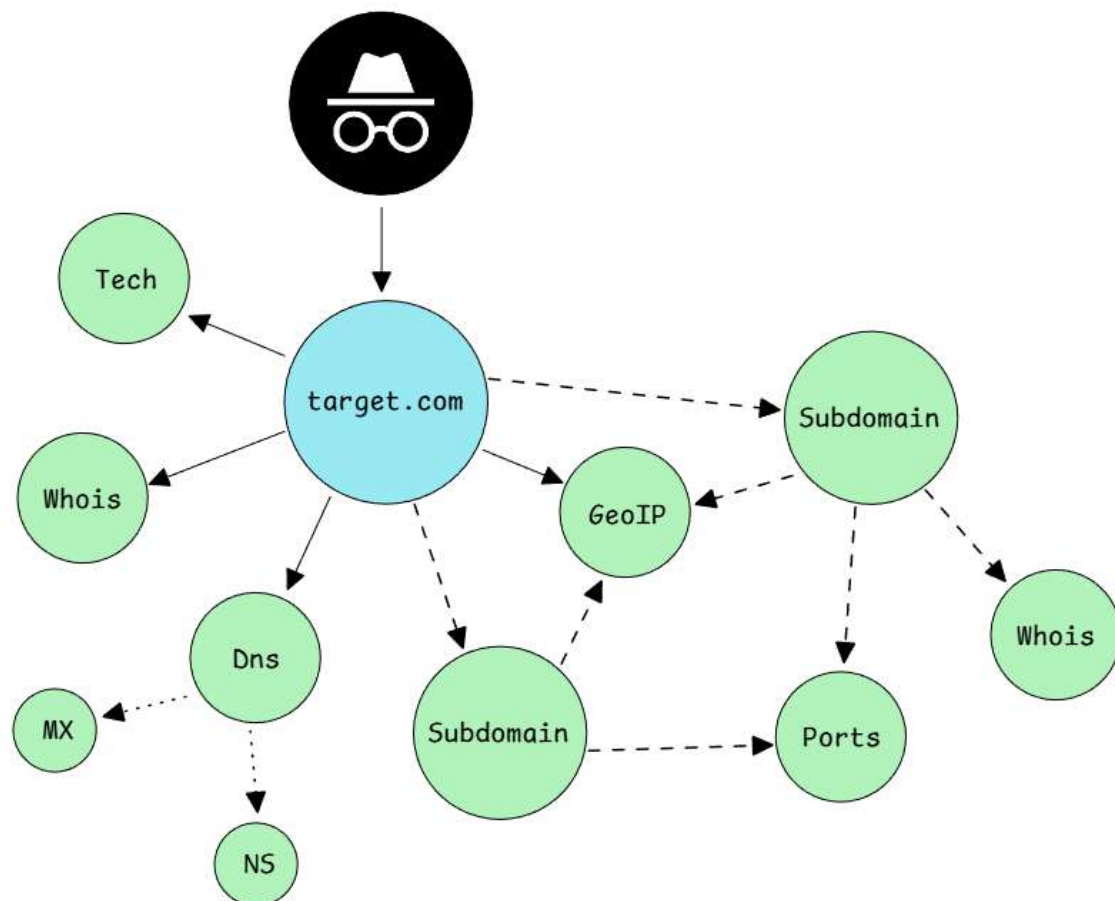
A diferencia de un analista OSINT tradicional, el OSINT Pentester aplica sus habilidades en un contexto ofensivo y técnico, orientado a la detección temprana de superficies de ataque, vectores potenciales y relaciones ocultas entre sistemas, dominios, usuarios o servicios. Su enfoque es estratégico: busca maximizar la información obtenida sin ser detectado y sin generar tráfico o ruido que pueda alertar al objetivo.

Esta etapa de reconocimiento, bien ejecutada, **define la eficiencia y el éxito de toda la operación de pentesting**. Un equipo que dispone de inteligencia precisa desde el inicio puede optimizar sus recursos, priorizar los vectores de ataque más prometedores y reducir drásticamente los tiempos de explotación.

En un entorno Red Team, el OSINT Pentester cumple un papel esencial:

- Identifica dominios y subdominios expuestos.
- Analiza metadatos de documentos públicos.
- Detecta correos corporativos y posibles credenciales filtradas.
- Reconstruye la huella digital de la organización.
- Correlaciona información técnica con fuentes humanas y sociales.

El resultado es un **mapa detallado del ecosistema del objetivo**, donde cada pieza de información contribuye a entender su superficie de ataque desde una perspectiva realista.



## ***Perfil Técnico del OSINT Pentester***

El **OSINT Pentester** es un perfil híbrido dentro del ámbito de la seguridad ofensiva. Combina las capacidades analíticas de un investigador con las habilidades técnicas de un hacker ético. Su enfoque está orientado a **entender, mapear y explotar la información pública** de un objetivo para fortalecer la fase de reconocimiento de una prueba de penetración.

### **1. Habilidades Clave**

- **Pensamiento analítico y enfoque metodológico:** el OSINT Pentester no busca información al azar, sino que trabaja con una mentalidad estructurada basada en hipótesis. Cada dato obtenido tiene un propósito dentro del proceso de investigación.
- **Conocimiento técnico avanzado:** entiende el funcionamiento de redes, protocolos, infraestructura web, DNS, servidores, tecnologías y sistemas

operativos, lo que le permite contextualizar la información recolectada y detectar posibles puntos débiles.

- **Capacidad de anonimato y evasión:** sabe operar de manera discreta, utilizando técnicas para evitar la detección durante el reconocimiento pasivo.
- **Correlación y análisis de datos:** es capaz de conectar piezas de información dispersas —desde dominios, correos y metadatos hasta menciones en redes sociales— para construir una visión integral del objetivo.
- **Documentación y comunicación:** traduce hallazgos técnicos en reportes comprensibles y de valor estratégico para el resto del equipo de pentesting o para el cliente final.

## 2. Mentalidad y Enfoque

El OSINT Pentester trabaja con una **mentalidad de inteligencia**. Su objetivo no es acumular grandes volúmenes de datos, sino **descubrir información relevante, verificable y útil**. Este enfoque lo diferencia de un recolector de datos tradicional. La precisión, el contexto y la verificación son los pilares de su proceso.

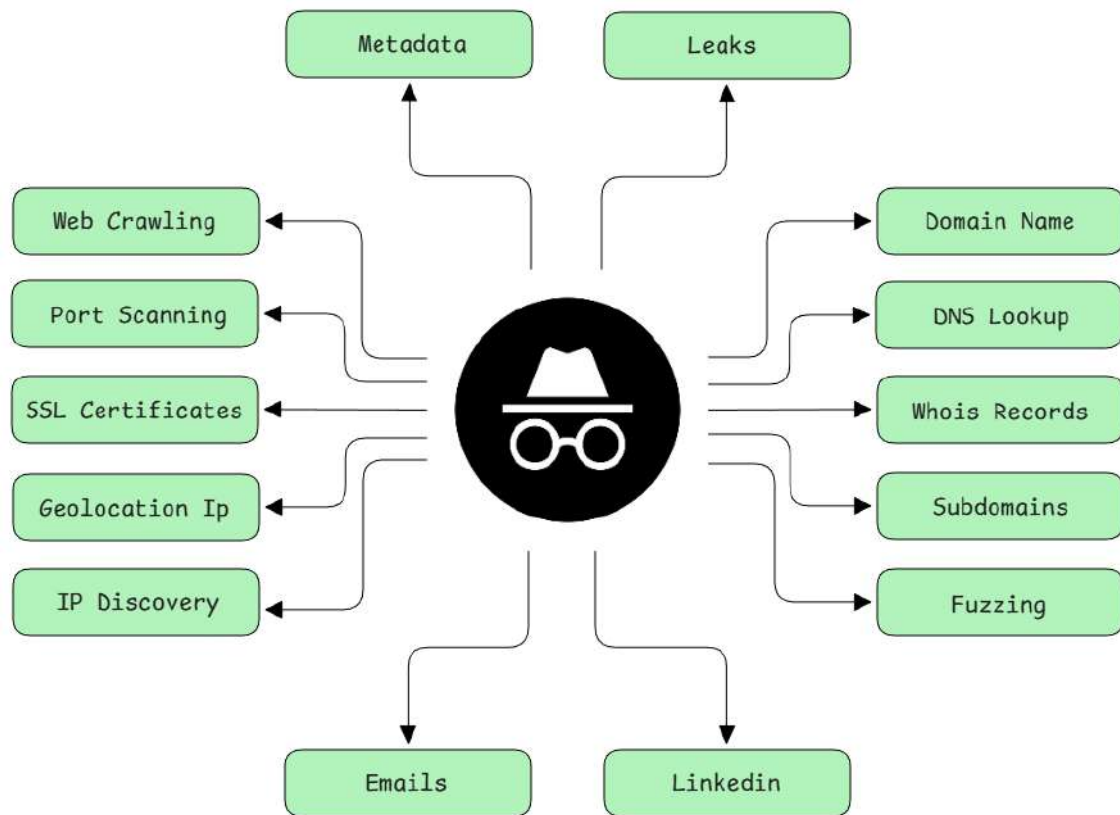
Además, posee una visión **creativa y lateral**, capaz de seguir rastros digitales poco evidentes o inferir relaciones indirectas entre elementos del ecosistema digital del objetivo. Esta capacidad para “pensar como un atacante” le permite anticiparse a posibles rutas de intrusión antes de que sean explotadas.

## 3. Herramientas y Técnicas Comunes

Aunque el arsenal de herramientas puede variar según el estilo y el alcance del proyecto, un OSINT Pentester suele combinar **fuentes abiertas, técnicas de automatización y scripts personalizados** para optimizar su trabajo. Entre las más utilizadas se encuentran:

- **Reconocimiento de dominios y subdominios:** *Alienvault, Subfinder, Dorks*.
- **Recolección de metadatos y archivos públicos:** *Exiftool, FOCA, Metagoofil*.
- **Búsqueda de correos y credenciales filtradas:** *Have I Been Pwned, Holehe, SnusBase, Leaked.domains*.
- **Análisis de redes y servicios:** *Shodan, Censys, Fofa, Netlas*.
- **Scraping y análisis web:** *theHarvester, Spiderfoot, Maltego, recon-ng*.
- **Automatización de flujos OSINT personalizados:** *scripts en Bash, Power Shell, Python*.

Estas herramientas son solo una parte del proceso. El verdadero valor del OSINT Pentester reside en su **capacidad para interpretar y transformar los datos en inteligencia aplicable**, aportando contexto y priorización a la información.



## Cómo el OSINT se Convierte en Inteligencia

El valor del OSINT dentro de una prueba de penetración no reside únicamente en la cantidad de información que se logra obtener, sino en la **capacidad de transformar esos datos en conocimiento accionable**. La verdadera inteligencia nace cuando los datos se procesan, se verifican y se conectan de forma que permitan comprender el entorno objetivo con precisión y profundidad.

En otras palabras: **los datos sin análisis son solo ruido**. La inteligencia surge cuando el OSINT Pentester logra responder preguntas concretas del tipo:

- ¿Qué tecnologías utiliza el objetivo?
- ¿Qué activos están expuestos y son susceptibles a explotación?
- ¿Qué usuarios o correos corporativos podrían representar un vector inicial de ataque?
- ¿Qué relaciones entre dominios, servidores o proveedores pueden ofrecer rutas de intrusión indirectas?

## 1. Recolección

La primera etapa del proceso consiste en **capturar información pública y accesible** desde una amplia variedad de fuentes abiertas. Esto incluye motores de búsqueda, registros DNS, plataformas sociales, leaks de credenciales, repositorios de código, información WHOIS, y más.

El objetivo es reunir el máximo de datos posibles **sin generar interacción directa con el objetivo**, manteniendo la naturaleza pasiva del reconocimiento OSINT.

## 2. Filtrado y Clasificación

Una vez recolectados los datos, el siguiente paso es **depurarlos y organizarlos**. Aquí se eliminan duplicados, se descarta información irrelevante y se clasifican los hallazgos según su tipo (infraestructura, personal, servicios, tecnología, etc.).

Este filtrado es esencial para evitar la saturación de datos y concentrarse en la información realmente útil.

## 3. Correlación y Análisis

En esta fase, el OSINT Pentester **conecta los puntos**. Cruza información técnica (dominios, IPs, servidores) con información humana o social (empleados, correos, roles) y con fuentes adicionales (repositorios, leaks, metadatos, documentos).

El propósito es **revelar patrones, relaciones y dependencias** que no son evidentes a simple vista. Por ejemplo, un dominio aparentemente secundario puede compartir infraestructura con el sistema principal, o un correo expuesto en una filtración puede dar acceso a un servicio interno.

## 4. Producción de Inteligencia

Con los datos analizados, se genera un **informe o producto de inteligencia**. Este documento describe de forma clara los hallazgos relevantes, acompañados de evidencia, contexto y recomendaciones tácticas.

En esta etapa, el OSINT deja de ser “información descriptiva” y se convierte en **inteligencia operativa**, capaz de orientar decisiones dentro del pentest: priorizar objetivos, definir vectores de ataque y planificar las acciones del Red Team.

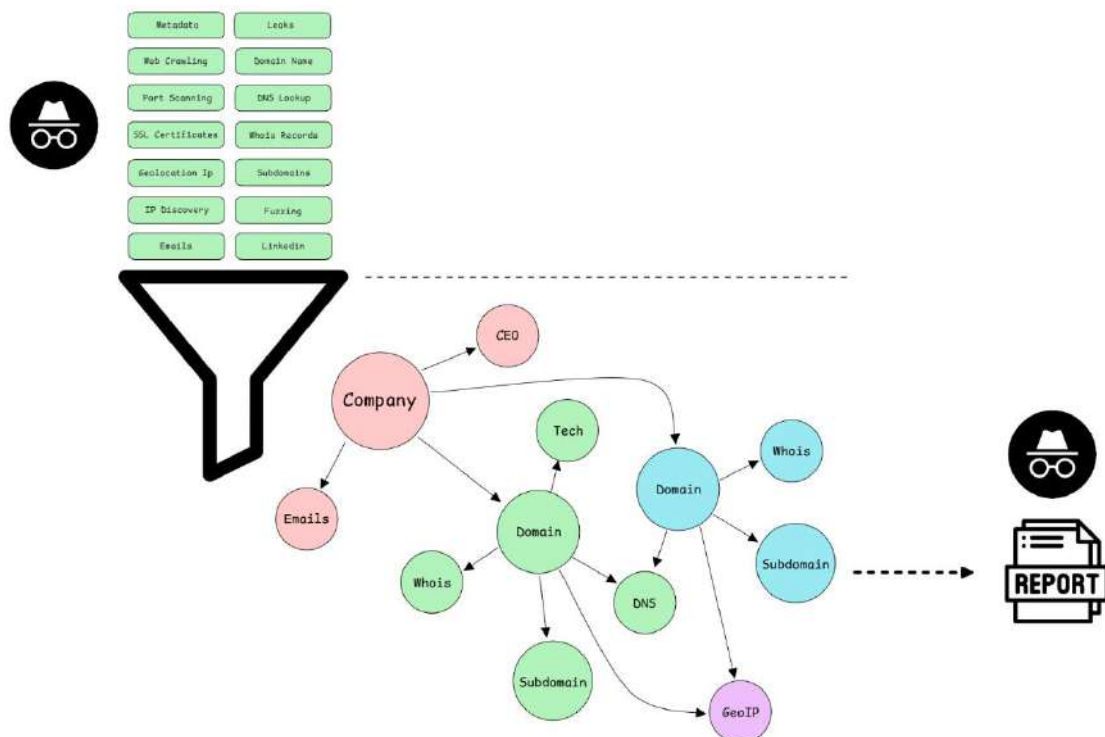
## 5. Retroalimentación y Actualización



La inteligencia no es estática. Un buen OSINT Pentester **revisa y actualiza constantemente sus hallazgos** a medida que avanza la prueba, adaptando el enfoque según los resultados obtenidos. Esta retroalimentación continua permite mantener la información actualizada y garantizar que las acciones del pentest se basen siempre en datos válidos.

El proceso completo de transformación de OSINT en inteligencia es lo que **marca la diferencia entre un reconocimiento superficial y una operación de penetración verdaderamente estratégica.**

Un pentest con inteligencia sólida detrás no solo descubre vulnerabilidades, sino que entiende su contexto, impacto y prioridad dentro del entorno objetivo.



## TTPs prácticos del OSINT Pentester — Reconocimiento rápido

A continuación, se enumeran ejemplos prácticos con formato estructurado tipo TTPs (tácticas, técnicas, procedimientos y herramientas) al estilo MITRE que un OSINT Pentester utiliza para desempeñar esta fase de reconocimiento con OSINT ofensivo.

### 1. Tecnologías y versiones (aplicativos, servicios)

- Táctica: identificar tecnologías y versiones expuestas para evaluar vectores conocidos y credenciales por defecto.

- Técnicas/Herramientas: fingerprinting con *Wappalyzer*, *BuiltWith*, *WhatWeb*, *Nmap* (*-sV*) y búsquedas en headers/respuestas HTTP.
- Inteligencia: priorizar vectores con CVE conocidos, listar servicios con mayor probabilidad de explotación y comprobar si existen credenciales por defecto o versiones vulnerables en inventario.

## 2. Dorks para encontrar /admin o /login

- Táctica: usar queries específicas en buscadores para localizar interfaces de administración y paneles de acceso.
- Técnicas/Herramientas: Google/Bing dorks, *StartPage*, operadores site: inurl: intitle:.
- Inteligencia: mapear puntos de entrada para intentos de autenticación dirigidos y correlacionar paneles con subdominios/tecnologías para priorizar pruebas.

## 3. Nombres de usuarios / autores / correos para validar en logins

- Táctica: recopilar identidades y correos públicos que puedan ser usernames para pruebas de autenticación.
- Técnicas/Herramientas: LinkedIn scraping manual, GitHub, perfiles públicos, leaks (*HavelBeenPwned*, *Dehashed*).
- Inteligencia: construir lista priorizada de credenciales potenciales (usernames) y correlacionarlas con servicios vulnerables o paneles detectados.

## 4. Código frontend comentado o deshabilitado con rutas/endpoints

- Táctica: revisar el frontend por comentarios o código muerto que revele rutas internas o endpoints.
- Técnicas/Herramientas: inspeccionar DOM, revisar *JS* y *source maps*, buscar en repositorios públicos (GitHub, GitLab).
- Inteligencia: extraer endpoints escondidos, endpoints administrativos o APIs internas y planificar pruebas dirigidas contra esos paths.

## 5. Código frontend en búsqueda de credenciales, tokens o claves

- Táctica: buscar artefactos sensibles dejados en código público (API keys, tokens, secretos expuestos).
- Técnicas/Herramientas: búsquedas en repositorios, *gitrob*, *Gitleaks*, *grep/rg* sobre files descargados.
- Inteligencia: validar la validez de credenciales encontradas, identificar servicios afectados y explotar accesos o escalar previa autorización.

## 6. Detección de tecnologías y versiones de la aplicación

- Táctica: identificar stack completo (frontend/back, frameworks, libs) para mapear riesgos específicos.
- Técnicas/Herramientas: análisis de encabezados HTTP, archivos públicos (package.json, pom.xml), fingerprinting con *WhatWeb/Wappalyzer*.
- Inteligencia: correlacionar versiones con exploits conocidos y priorizar vectores de explotación por riesgo real.

## 7. Whois de IPs y dominios para datos de registrantes

- Táctica: obtener información registral para descubrir contactos, organizadores o infraestructuras relacionadas.
- Técnicas/Herramientas: *whois*, RDAP, registrars web, historic WHOIS (DomainTools).
- Inteligencia: vincular dominios relacionados, detectar adquisiciones/propietarios alternativos y encontrar emails o teléfonos útiles para ingeniería social.

## 8. Infraestructura: DNS, MX, servidores, hosting, cloud, proxies

- Táctica: mapear la infraestructura para conocer proveedores, puntos de fallo y relaciones entre activos.
- Técnicas/Herramientas: *dig*, *dnsenum*, *Amass*, *MXToolbox*, Shodan/Censys, pasarela WHOIS/RDAP.
- Inteligencia: identificar proveedores críticos (CDN, mail), dominios secundarios co-ubicados y rutas alternativas de ataque (proveedores débiles).

## 9. Perfilamiento del CEO / founders / empleados (LinkedIn)

- Táctica: recolectar información personal y profesional que permita spear-phishing o ingeniería social dirigida.
- Técnicas/Herramientas: LinkedIn, Twitter, bios públicas, scraping manual; revisar historial laboral y conexiones.
- Inteligencia: crear vectores de spear-phishing con contexto real (proveedores, proyectos, relaciones) y priorizar targets con acceso sensible.

## 10. Información general de la empresa (razón social, CUIT, rubro, partners)

- Táctica: obtener datos corporativos formales para contextualizar la superficie de ataque y legitimidad en engaños.

- Técnicas/Herramientas: registradores públicos, páginas de AFIP/registro mercantil, facturas públicas, prensa y socios.
- Inteligencia: elaborar escenarios de suplantación creíbles (emails de proveedores, facturas) y detectar terceros con acceso a sistemas.

## **11. Geolocalización de IPs y servidores**

Táctica: ubicar físicamente infraestructura para entender jurisdicción, latencia y posibles vectores locales.

Técnicas/Herramientas: GeoIP, RIPE/APNIC/ARIN lookups, traceroute, Shodan.

Inteligencia: priorizar objetivos por jurisdicción, identificar data centers y correlacionar con proveedores/regulaciones.

- Táctica: ubicar físicamente infraestructura para entender jurisdicción, latencia y posibles vectores locales.
- Técnicas/Herramientas: GeoIP, RIPE/APNIC/ARIN lookups, traceroute, Shodan.
- Inteligencia: priorizar objetivos por jurisdicción, identificar data centers y correlacionar con proveedores/regulaciones.

## **12. Documentación interna / paneles de registro / documentación de API**

- Táctica: buscar manuales, guías o docs públicos que revelen endpoints, parámetros o procesos internos.
- Técnicas/Herramientas: portales de desarrollador públicos, archivos robots.txt, repos public, Wayback Machine, Google dorks.
- Inteligencia: extraer flujos lógicos y endpoints críticos para diseñar pruebas de API y escenarios de abuso autorizados.

## **13. Imágenes y fotos de la empresa (Google Maps, redes)**

- Táctica: examinar imágenes para información física (nombres, equipos, etiquetas de hardware, planos).
- Técnicas/Herramientas: Google Maps/Street View, Flickr, redes sociales corporativas; análisis EXIF con *Exiftool*.
- Inteligencia: identificar dispositivos/placas, ubicaciones de servidores o pistas logísticas que faciliten ataques físicos o de ingeniería social.

## **14. Puertos activos (escaneo de red)**

- Táctica: detectar servicios expuestos y versiones que indiquen vectores de explotación.
- Técnicas/Herramientas: *Nmap* (sS, sV), Masscan (cuando está permitido), Shodan para escaneos pasivos.

- Inteligencia: construir inventario de servicios expuestos y priorizar pruebas de explotación según riesgo y criticidad.

## 15. Fuzzing de rutas y directorios

- Táctica: descubrir rutas ocultas, backups o endpoints sensibles no indexados.
- Técnicas/Herramientas: *ffuf*, *dirbuster*, *gobuster*, *wfuzz* con wordlists contextualizadas.
- Inteligencia: identificar paneles secretos, archivos de configuración o endpoints de administración que abran rutas de acceso durante explotación.

## Contacto

 <https://www.linkedin.com/in/david-padron-9a74aa323/>

 <https://github.com/FeathersMcgr4w>

 <https://feathersmcgr4w.github.io/cyber-portfolio/>